Trivy Scan Report

FoodtruckApp — Sprint 3 — filesystem scan

Tool	Trivy 0.76.0 (Aqua Security), official Windows x64 build
Scan type	**Filesystem** — `trivy fs` over the repository root
Scanners	`vuln`, `secret`, `misconfig`
Dependency source	npm graph resolved from `package-lock.json` (1 lock file detected)
Where executed	Locally on Windows 11; not in CI
Repository	`https://github.com/Unuvert1/FoodtruckApp`
Commit	`5570aa3ac82fee8a03cbccfcff0a72631e073a4d`
Scan date	October 20, 2026

Command

```
trivy fs --scanners vuln,secret,misconfig \
  --skip-dirs node_modules --skip-dirs .next --skip-dirs .git \
  --skip-dirs lib/generated --skip-files .env.local \
  --format json -o trivy.json .
```

A second run with `--include-dev-deps` returned the identical 14 findings, so no vulnerability is hidden in the development-only dependency tree.

Severity counts

0	8	6	0
CRITICAL	HIGH	MEDIUM	LOW

Scanner	Result
Vulnerabilities	14 total — 0 CRITICAL, 8 HIGH, 6 MEDIUM, 0 LOW
Hard-coded secrets	**0** — the secret scanner ran over the tree and found nothing
Misconfigurations	**0** — no Dockerfile, Kubernetes or Terraform files exist in this repository to check

Findings

Every finding is in a transitive dependency. None is in code written by this team.

Severity	Vulnerability	Package	Installed	Fixed in	CVSS
HIGH	`CVE-2026-104850`	`@modelcontextprotocol/sdk`	`1.30.0`	`1.31.0`	7.5
HIGH	`CVE-2026-93687`	`braces`	`3.0.3`	`no fix yet`	7.5
HIGH	`CVE-2026-40345`	`deepmerge-ts`	`7.1.5`	`8.0.0`	—

HIGH	GHSA-3f6p-5ww8-9rcr	mysql2	3.15.3	3.22.0	—
HIGH	CVE-2026-45623	postcss	8.4.31	8.5.12	9.1
HIGH	CVE-2026-73646	postcss	8.4.31	8.5.18	7.5
HIGH	GHSA-wq5f-xc86-pv6w	sharp	0.35.4	0.35.5	—
HIGH	CVE-2026-93749	source-map-js	1.2.1	1.2.2	7.5
MEDIUM	CVE-2026-111757	hono	4.13.8	4.13.11	5.3
MEDIUM	GHSA-rgwj-5xj2-c3m3	mysql2	3.15.3	3.23.1	5.9
MEDIUM	CVE-2026-94484	next	15.5.25	16.3.8, 15.5.27	4.8
MEDIUM	CVE-2026-94543	next	15.5.25	15.5.27, 16.3.8	5.3
MEDIUM	CVE-2026-41305	postcss	8.4.31	8.5.10	6.1
MEDIUM	CVE-2026-69153	postcss	8.4.31	8.5.23	5.3

What each finding is, and where it comes from

Severity	Vulnerability	Description	Dependency path
HIGH	CVE-2026-104850	MCP TypeScript SDK: Information disclosure via unbound OAuth credentials	`shadcn 4.21.0 → @modelcontextprotocol/sdk`
HIGH	CVE-2026-93687	Denial of Service via Stack Overflow from Deeply Nested Patterns	`shadcn 4.21.0 → fast-glob → micromatch → braces`
HIGH	CVE-2026-40345	DeepmergeTS has stack exhaustion when merging recursive object graphs	`prisma 7.10.0 → @prisma/config → deepmerge-ts`
HIGH	GHSA-3f6p-5ww8-9rcr	Auth Plugin Downgrade to mysql_clear_password Leaks Plaintext Credentials	`prisma 7.10.0 → mysql2`
HIGH	CVE-2026-45623	Information disclosure and denial of service via crafted CSS input	`next 15.5.25 → postcss 8.4.31 (pinned by Next)`
HIGH	CVE-2026-73646	Information disclosure via path traversal in source map auto-loading	`next 15.5.25 → postcss 8.4.31 (pinned by Next)`
HIGH	GHSA-wq5f-xc86-pv6w	Vulnerability in librsvg dependency CVE-2026-96889	`next 15.5.25 → sharp`
HIGH	CVE-2026-93749	Denial of Service via malformed indexed source maps	`next 15.5.25 → postcss → source-map-js`
MEDIUM	CVE-2026-111757	Information disclosure via malformed percent-encoded paths in serveStatic	`shadcn 4.21.0 → @modelcontextprotocol/sdk → hono`
MEDIUM	GHSA-rgwj-5xj2-c3m3	Unbounded zlib inflate in compressed MySQL protocol handler allows decompression-bomb DoS	`prisma 7.10.0 → mysql2`
MEDIUM	CVE-2026-94484	Denial of Service via response cache poisoning	`direct dependency`
MEDIUM	CVE-2026-94543	Response cache poisoning via improper route binding	`direct dependency`
MEDIUM	CVE-2026-41305	Cross-Site Scripting (XSS) via improper escaping of style closing tags	`next 15.5.25 → postcss 8.4.31 (pinned by Next)`
MEDIUM	CVE-2026-69153	Information disclosure via crafted sourceMappingURL	`next 15.5.25 → postcss 8.4.31 (pinned by Next)`

Where the risk concentrates

Root entry in package.json	Findings	HIGH	MEDIUM	Assessment
`shadcn 4.21.0`	3	2	1	A scaffolding CLI listed under `dependencies` rather than `devDependencies`. It pulls in an MCP server SDK and a web framework (`hono`) that this app never runs. Nothing imports it at runtime.
`next 15.5.25`	8	4	4	Two findings are in Next.js itself (cache poisoning, both fixed in 15.5.27); the rest are the old `postcss` 8.4.31 that Next pins internally, plus `sharp`.

`prisma 7.10.0`	3	2	1	The two `mysql2` findings are in a MySQL driver that ships with the Prisma CLI. This project uses PostgreSQL, so that driver is never loaded and neither issue is reachable.

Remediation plan

Priority	Action	Clears
1	Move `shadcn` out of `dependencies` and invoke it with `npx shadcn@latest` when scaffolding a component.	3 findings (2 HIGH, 1 MEDIUM)
2	Upgrade Next.js to 15.5.27.	2 MEDIUM directly, and refreshes the pinned `postcss` and `sharp` that account for 7 more
3	Add a `trivy fs --exit-code 1 --severity HIGH,CRITICAL` step to a GitHub Actions workflow.	Stops the next one arriving unnoticed
4	Accept and document the remaining items: `mysql2` (unreachable — wrong database driver) and `braces` (no upstream fix published).	—

These changes were **not** applied in this sprint: the scan was run after the sprint's feature work was already merged, and a dependency upgrade on the last day would have gone in untested. They are the first items for Sprint 4.

> **"This static analysis was generated using automated tools during this sprint."**

Trivy Scan Report · FoodtruckApp Sprint 3 · commit `5570aa3` · October 20, 2026 · This static analysis was generated using automated tools during this sprint.